

Informe de Investigación de Alerta SOC

1. Información General de la Alerta

Analista: Joaquín Picazo

ID del evento: 8

Fecha y hora del evento: Aug, 29, 2020, 11:05 PM

Nombre de la regla / alerta: SOC101 - Phishing Mail Detected

Dirección SMTP: 63.35.133.186

Dirección de origen: info@nexoiberica.com

Dirección de destino: mark@letsdefend.io

Asunto del correo: UPS Express

Acción: Allowed

Severidad: Baja

2. Resumen Ejecutivo

La alerta se generó debido a un ataque de phishing dirigido al usuario Mark, el cual simulaba ser un aviso de entrega de UPS Express. Tras la investigación, se confirmó como un Verdadero Positivo. Se verificó que el usuario descargó y ejecutó un documento con macros maliciosas (troyano downloader), provocando que el equipo infectado realizara conexiones de red hacia infraestructura maliciosa conocida (qstride.com). El dispositivo de Mark fue contenido en la red para mitigar el ataque, y se requiere el bloqueo de los indicadores de compromiso.

3. Pasos de la Investigación

La investigación comenzó analizando el correo electrónico alertado, confirmando la existencia de una URL dirigida a un archivo descargable.

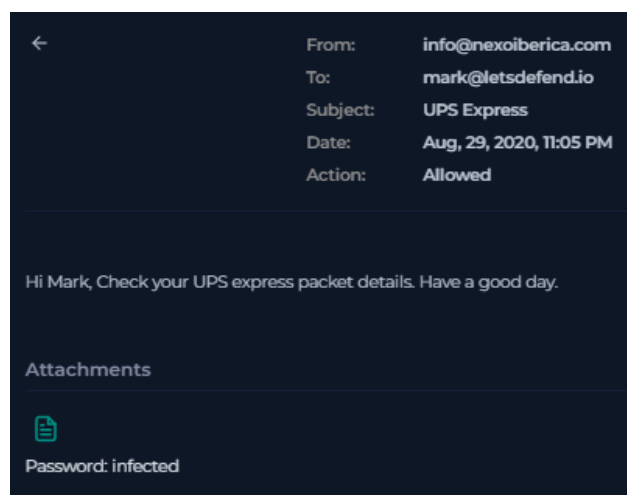


Figura 1: Análisis inicial del correo electrónico malicioso.

La inspección de la URL mediante VirusTotal confirmó su naturaleza maliciosa al alojar recursos externos con código dañino.

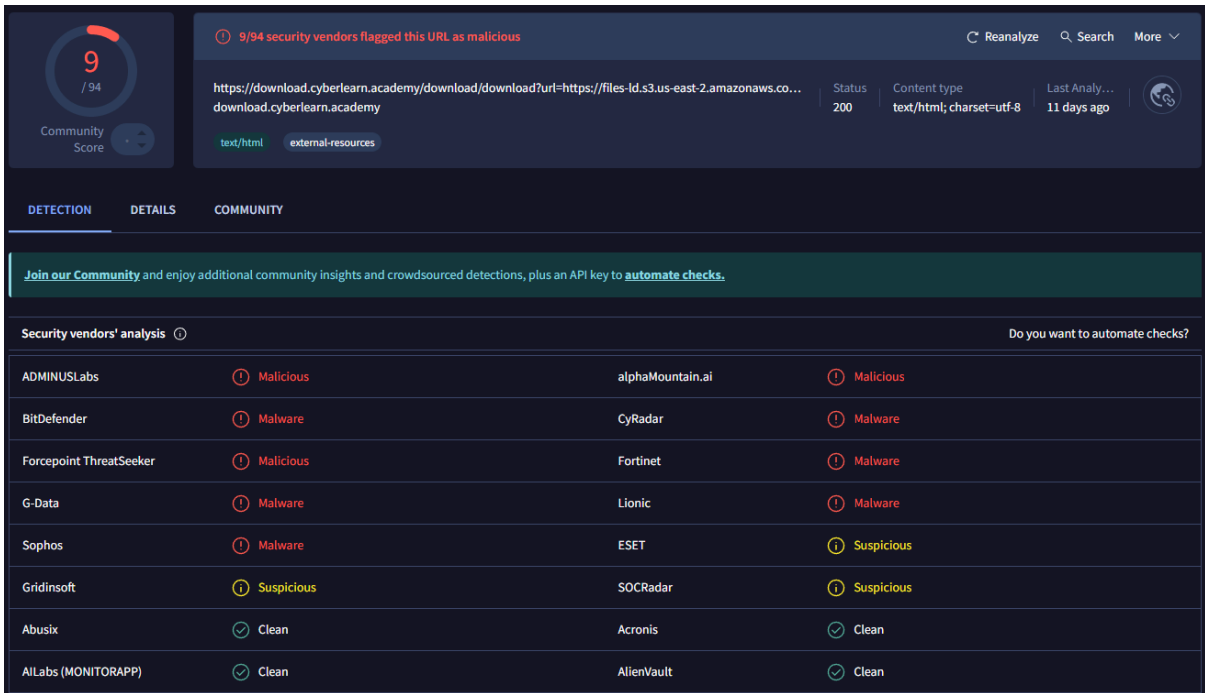


Figura 2: Verificación de peligrosidad de URL en VirusTotal.

El análisis posterior del archivo descargable permitió identificarlo como un troyano.

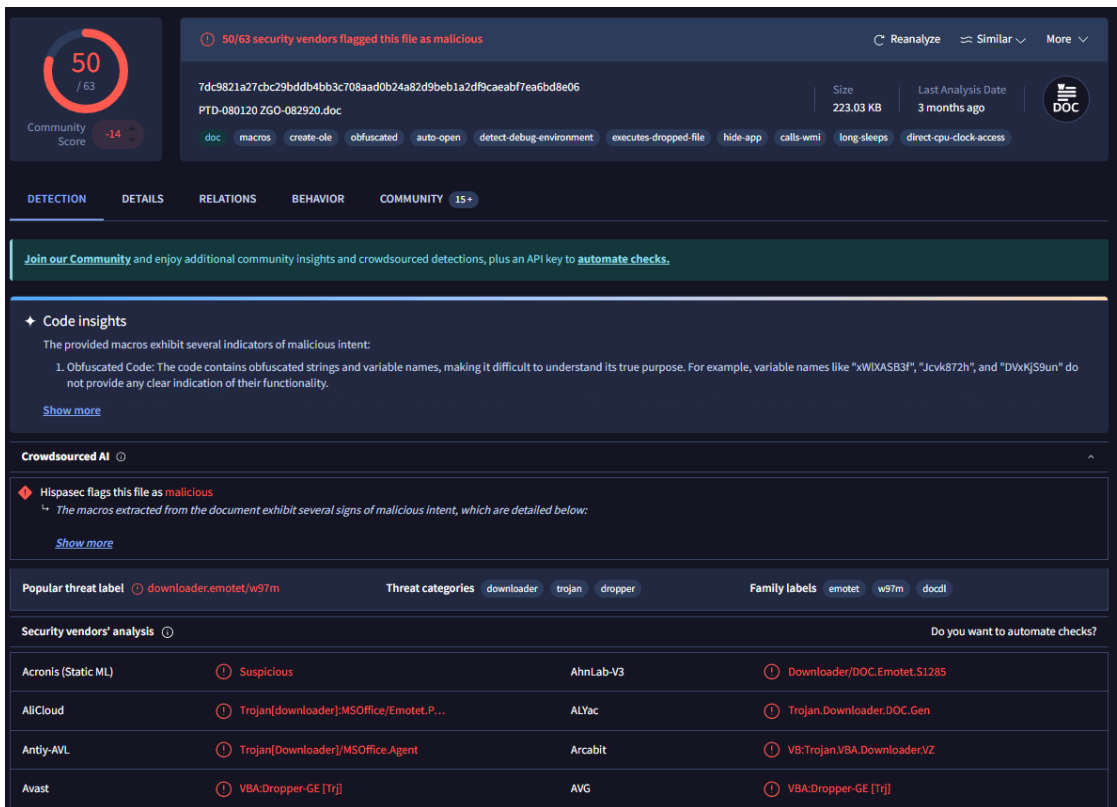


Figura 3: Identificación del archivo malicioso.

Al ejecutar el archivo, se detectaron peticiones hacia qstride.com, un sitio malicioso cuyo análisis completo del comportamiento se puede consultar en el reporte de [ANY.RUN](#).

DNS requests

Domain	IP	Reputation
qstride.com	3.94.41.167 52.86.6.113	malicious
www.hugedomains.com	104.26.6.37 104.26.7.37 172.67.70.191	whitelisted
tskgear.com	103.197.57.20	unknown
secure.globalsign.com	104.18.21.226 104.18.20.226	whitelisted
vermasiyaahi.com	54.161.222.85 34.205.242.146	whitelisted
www.weblabor.com.br	84.32.84.37	unknown
ctldl.windowsupdate.com	87.248.205.0	whitelisted
viniciusrangel.com	191.6.210.76	unknown
westvac.com	104.21.47.185 172.67.171.207	unknown
viewall.eu	185.37.70.34	malicious

Previous12Next

10

Figura 4: Detección de comunicaciones maliciosas en entorno controlado.

El registro de ejecución evidencia claramente el comportamiento del malware.

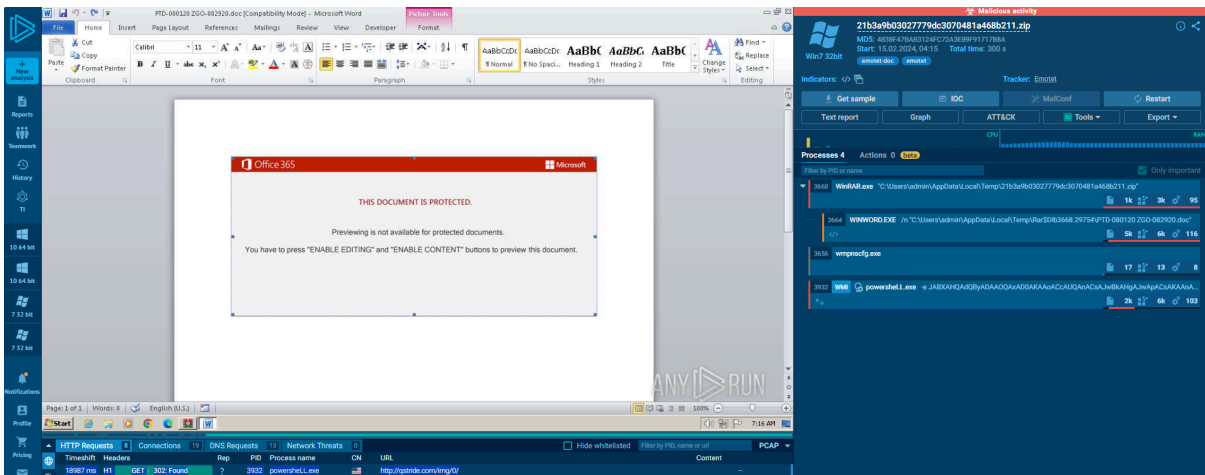


Figura 5: Registro de ejecución del malware.

Los logs de red confirmaron conexiones hacia el dominio malicioso y validaron que el archivo se ejecutó correctamente en el equipo.

Raw Log contains "http://qstride.com/img/0/"

✓ 1 events (before Aug, 29, 2020, 10:28 PM UTC)

< Hide Fields

INTERESTING FIELDS

α type

α source_address

source_port

α destination_address

destination_port

α raw_log

Event

Field	Value
type	Proxy
source_address	172.16.17.14
source_port	47741
destination_address	198.100.45.154
destination_port	80
time	Aug, 29, 2020, 10:28 PM
Raw Log	
Request URL	http://qstride.com/img/0/
Request Method	GET
Device Action	Permitted

1 row selected

Figura 6: Evidencia de logs de red sobre el compromiso del equipo.

Debido al compromiso del equipo, se procedió con el aislamiento inmediato del dispositivo para contener la amenaza y permitir un análisis forense posterior, escalando el caso a nivel L2.

772.16.17.14

Walton-Memimage
772.16.17.145

Matthew
772.16.17.148

Kelsey
772.16.17.147

Hadley
772.16.17.142

Angela
772.16.17.143

Veronica
772.16.17.141

Henry
772.16.17.149

VMServer
772.16.17.146

Cruft
772.16.17.144

MikeComputer
772.16.17.14

Endpoint Information

Host Information

Hostname: MikeComputer

IP Address: 772.16.17.14

OS: Windows 10

Client/Server: Client

Domain: LetsDefend

Bit Level: 64

Primary User: MikeOl

Last Login: Aug, 29, 2020, 07:31 PM

Action

Containment: ☒ Host Contained

Processes

Network Action

Terminal History

Browser History

Results: 10

EVENT TIME	PROCESS ID	PROCESS NAME	PARENT PROCESS	COMMAND LINE
2020-08-29 10:27	No Process ID	powershell.exe	—	No Command
2020-08-29 10:27	No Process ID	cmd.exe	—	c:\program files\cmd.exe /c cd /d c:\program files\cmd.exe
2020-08-29 10:29	No Process ID	outlook.exe	—	c:\program files (x86)\microsoft office\office15\outlook.exe
2020-08-29 11:29	No Process ID	Chrome.exe	—	c:\program files (x86)\google\chrome\application\chrom...

< 1 >

Figura 7: Acción de contención y aislamiento del dispositivo afectado.

4. Veredicto y contención

Este caso es un verdadero positivo. Realizaron ataque de Phishing por correo electrónico a usuario Mark, en el cual Mark descargó y abrió el archivo, el cual era un TROYANO. El ataque de Phishing consistía en descargar un archivo .zip desde el navegador, extraer el contenido y abrir el archivo que contiene (.doc), el cual ejecuta solicitudes y ejecuciones de scripts. Como se detectó que Mark ejecutó el archivo malicioso y se envió solicitud a <http://qstride.com/> se procedió a contener el dispositivo de Mark. Se recomienda bloquear las IP detectadas como maliciosas y aumentar la concientización (sobre phishing) del personal inmediatamente.